Third-Party Cybersecurity Risk Assessment

Public Evidence Edition

Vendors assessed: Atlassian, Greenhouse Software, Notion

Document control	
Status	Final for portfolio review
Assessment date	24 September 2026. All sources retrieved on this date.
Assessment type	Desk-based (basic) due diligence using publicly available information, per the NIST SP 1326 definition
Frameworks referenced	NIST SP 800-161r1, SP 1326, SP 800-30r1, CSF 2.0, SP 800-53r5; ISO/IEC 27001:2022, 27036, 27005, ISO 31000:2018. Alignment only — no compliance or certification is claimed.
Client scenario	Fictional multinational enterprise (about 3,000 staff, EU and US operations, GDPR-regulated).
Classification	Public — educational portfolio material
Next scheduled review	Annual, or earlier on a material vendor change (see Section 9.3)

Contents

1 Executive summary **2**

2 Scope, context and objectives **4**
2.1 Objective and approach 4
2.2 What NIST SP 1326 says this assessment is 4
2.3 Fictional client scenario and use cases 4

3 Methodology **6**
3.1 Evidence hierarchy 6
3.2 Coverage status (control-level) 6
3.3 Risk model 6
3.4 Source quality grades 7

4 Results **8**
4.1 Residual risk by control 8
4.2 High residual items 8
4.3 Domain view 9

5 Vendor findings **10**
5.1 Atlassian 10
5.2 Greenhouse Software 10
5.3 Notion 11

6 Cross-vendor observations **13**

7 Sensitivity analysis **14**

8 Limitations, bias and independence **15**

9 Risk treatment plan and monitoring **16**
9.1 Evaluation criteria (ISO 31000 risk evaluation) 16
9.2 Prioritised actions 16
9.3 Monitoring triggers 17

10 Recommended further improvements to this project **18**

A Control catalogue and framework mapping **19**

B Full assessment matrix **21**
B.1 Atlassian 21
B.2 Greenhouse Software 23
B.3 Notion 26

C Evidence register **29**

D Source register **41**

E Framework and standards references **44**

F Vendor follow-up request list **46**
F.1 Atlassian 46
F.2 Greenhouse Software 46
F.3 Notion 46

1. Executive summary

This report assesses three SaaS vendors that a fictional client might rely on: Atlassian (Jira/ Confluence/JSM), Greenhouse Software (applicant tracking and onboarding) and Notion (internal wiki with AI features). Each vendor was assessed against a 27-control catalogue mapped to ISO/IEC 27001:2022 Annex A, NIST CSF 2.0, NIST SP 800-53r5 and SOC 2 criteria, using only public evidence retrieved on 24 September 2026. Every finding is traceable to a numbered evidence item, which cites a source, the page section and a paraphrased finding (Appendices C and D).

Headline results

Vendor	Tier	Addr.	Part.	Not evid.	Weighted cov.	High	Crit.	Limited src.*
Atlassian	1	21	6	0	79.3%	2	0	0
Greenhouse Software	2	21	5	1	77.6%	2	1	0
Notion	2	23	4	0	86.2%	1	0	0

*Controls where an indexed public source (mainly vendor FAQ sections) was not retrieved. This is a limitation of this review, not evidence of a control gap. See Section 8.

Coverage by vendor

Vendor	Addressed	Partial	Not evidenced	Total
Atlassian	21	6	0	27
Greenhouse Software	21	5	1	27
Notion	23	4	0	27

Key findings

- \textbf{Notion} has the deepest public evidence: 23 of 27 controls are Addressed with stated parameters (TLS 1.2+, AES-256, quarterly access reviews, 24-hour access removal, 72-hour breach notice, annual BC/DR tests). Its single High item is the absence of general customer-content retention periods (DAT-02).
- \textbf{Atlassian} (Tier 1, the most critical dependency) publishes a detailed contractual security exhibit, but three High items remain: no access-review cadence (IAM-04), no post-termination deletion timeframe (DAT-02) and no fixed incident-notification window (IR-02). Its SOC˜2 report is product-scoped (Jira and Confluence shown) and the FY26 report (period ended 30 Sep 2025) was not confirmed as issued on the Trust Center; the FY27 period closes on 30 Sep 2026.
- \textbf{Greenhouse} carries the most open items (2 High) largely because its detailed answers sit in a 251-answer FAQ that was indexed but not read. Two items are substantive: a disclosed

\textbf{third-party incident at supplier Klue (11 June 2026)} where compromised integration credentials reached Greenhouse sales/CRM data (root cause still open on the page reviewed), and MFA enforcement not being evidenced.

- \textbf{Do not read this as a vendor league table.} The results measure how much public evidence was retrievable, not how secure each vendor is. Notion publishes its controls with parameters on one page; the other two publish more behind FAQs and gated reports.
- \textbf{AI-provider concentration} is a growing fourth-party exposure: Notion lists roughly a dozen AI/LLM and search subprocessors; Greenhouse discloses Anthropic and OpenAI; Atlassian's current public AI documentation was reviewed for the AI-01 criterion.

Priority actions (detail in Section 9)

- Obtain and read the SOC 2 Type II reports (scope, period, exceptions, complementary user-entity controls) and bridge letters for all three vendors, starting with Atlassian (Tier 1).
- Close three contractual gaps across vendors: incident-notification window, post-termination deletion timeframe, sub-processor change notice.
- Greenhouse: obtain the Klue incident root-cause summary and confirm MFA enforcement; remaining gaps are substantive evidence requests rather than source-review limitations.
- Set a monitoring calendar for time-bound artifacts: Atlassian FY27 SOC 2 (period ends 30 Sep 2026), Notion insurance evidence (expires Nov 2026), Greenhouse Onboarding pentest (last dated Q3 2025).

2. Scope, context and objectives

2.1 Objective and approach

The objective is to give a decision-maker a transparent, repeatable view of what public evidence supports for each vendor, where the assurance gaps are, and what to ask for next. The process follows the ISO 31000:2018 cycle (establish context, identify, analyse, evaluate, treat, monitor, communicate) and uses NIST SP 800-30r1 for likelihood/impact reasoning, NIST SP 800-161r1 for supplier criticality and C-SCRM practice, and NIST SP 1326 for the due-diligence scope.

2.2 What NIST SP 1326 says this assessment is

SP 1326 (final, 8 July 2026) distinguishes basic due diligence (desktop research using publicly available information) from enhanced due diligence (commercial datasets, proprietary sources, supply-chain illumination tools). This project is basic due diligence. SP 1326 organises assessments into five components; coverage here is:

SP 1326 component	Covered?	How
Foundational cyber practices	Yes	Controls GOV, IAM, DAT, VUL, IR, LOG, SDLC, ASSUR, AI
Resilience	Yes	BC-01, BC-02, SUP-03 (plus incident history in the vendor findings)
Supply chain tiers	Partly	Subprocessor transparency and supplier oversight (DAT-03, SUP-01, SUP-02, AI-01); fourth-party depth beyond the published lists was not analysed
Foreign ownership, control or influence (FOCI)	No	Out of scope. Recommended for an enhanced review
Provenance	No	Out of scope. Applies mainly to products and components

2.3 Fictional client scenario and use cases

The client is a fictional multinational (about 3,000 staff, EU and US operations, subject to GDPR). The use cases below are assumptions used to size impact; they are not facts about any real organisation.

Vendor	Assumed use case	Sens.	Crit.	Integ.	Lock-in	Reg.	Score	Tier
Atlassian	Jira / Confluence / Jira Service Management for engineering delivery and IT service management	4	5	4	4	3	4.0	1 (Critical)
Greenhouse Software	Applicant tracking and onboarding for a multinational workforce	4	3	3	3	4	3.4	2 (Important)
Notion	Company wiki and internal documentation workspace with AI features enabled	4	3	3	3	3	3.2	2 (Important)

Each factor is scored 1 (low) to 5 (high). Tier 1 (score 3.75 or more) calls for enhanced due diligence; Tier 2 (3.0

to 3.74) for basic plus targeted follow-ups; Tier 3 for basic only. Thresholds are project-defined.

3. Methodology

3.1 Evidence hierarchy

Leve	Name	Definition	Examples in this project
3	Independent	An independent attestation, certificate or third-party test artifact is publicly listed. Contents are usually gated, so existence is evidenced, not content.	SOC 2 Type II listing, ISO certificate, dated pentest report/letter
2	Vendor-specific	A specific vendor-authored control description or a published contractual exhibit, ideally with parameters.	Atlassian security-measures exhibit; Notion control statements
1	Assertion	Summary checklist, badge, marketing statement, self-attestation or indirect evidence.	Trust Center quick-summary ticks, SIG Lite, PCI SAQ
0	None	Nothing found in the reviewed sources. This does not mean the control is absent.	—

3.2 Coverage status (control-level)

- \textbf{Addressed} — the public source explicitly describes the control. Binary features (SSO, DPA, status page, bug bounty) need an explicit statement; operational controls (reviews, testing, DR, encryption) need at least one parameter such as a cadence, timeframe, protocol or algorithm. Addressed requires evidence level 2 or 3.
- \textbf{Partial} — the control is named or indirectly evidenced but scope, depth, parameters or product coverage are limited.
- \textbf{Not evidenced} — nothing relevant was found in the reviewed sources. Where a relevant source was \textit{indexed but not read}, the row is flagged \textbf{reviewer-limited} and is not treated as proof of absence.

3.3 Risk model

Residual Risk = Residual Likelihood x Impact, on a 5 x 5 scale, following the semi-quantitative approach of NIST SP 800-30r1. All parameters are project-defined assumptions, not ISO or NIST thresholds.

Element	Rule
Impact (1–5)	Set per control in the catalogue (3 to 5) from the client scenario: 5 for identity, data protection and incident response; 4 for other operational and assurance controls; 3 for methodology and risk-transfer items.
Residual likelihood	Addressed = 2; Partial = 3; Not evidenced = 4. A Not-evidenced row that is reviewer-limited is set to 3. Likelihood 1 is never assigned from public evidence; it is reserved for controls validated against an actual report or contract (enhanced due diligence).

Element	Rule
Adverse-event uplift	+1 (maximum 5) where a public, vendor-disclosed event in the last 24 months shows the control failing and root cause or remediation is not fully disclosed. Applied once: Greenhouse SUP-01 (Klue). This is a risk judgement, not a finding of fault.
Inherent likelihood	By vendor tier: Tier 1 = 5, Tier 2 = 4, Tier 3 = 3. Inherent risk = inherent likelihood x impact.
Confidence	Reported separately from risk: evidence level 3 = High, 2 = Medium, 1 = Low. Confidence is not multiplied into the score. It orders follow-up work (lowest confidence first among equal scores).

5×5 risk matrix

L \ I	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Bands (grayscale, darker = higher risk): Low 1–4; Medium 5–12; High 13–19; Critical 20–25.

3.4 Source quality grades

A+ = contractual document published by the vendor; A = full vendor trust portal fetched with dated content; B = vendor marketing/documentation page; C = partial excerpt or partly stale. Third-party blogs and review sites were excluded from scoring. Sources are grouped in Appendix D with retrieval date and depth of review (full page or excerpt only).

4. Results

4.1 Residual risk by control

Each row shows the residual score and coverage status for a control across all three vendors. Cells are shaded on a grayscale from white (Low) to black (Critical); no hue is used anywhere in this report. No control reached Critical or Low: public evidence alone cannot support a likelihood below 2, and no impact-5 control was wholly unevidenced.

Control	Atlassian	Greenhouse	Notion
GOV-01	8 Addressed	8 Addressed	8 Addressed
IAM-01	10 Addressed	10 Addressed	10 Addressed
IAM-02	10 Addressed	15 Partial	10 Addressed
IAM-03	10 Addressed	10 Addressed	10 Addressed
IAM-04	15 Partial	20 Not evid.	10 Addressed
DAT-01	10 Addressed	10 Addressed	10 Addressed
DAT-02	15 Partial	10 Addressed	15 Partial
DAT-03	10 Addressed	10 Addressed	10 Addressed
DAT-04	10 Addressed	10 Addressed	10 Addressed
DAT-05	8 Addressed	12 Partial	12 Partial
VUL-01	8 Addressed	8 Addressed	8 Addressed
VUL-02	8 Addressed	8 Addressed	8 Addressed
IR-01	10 Addressed	10 Addressed	10 Addressed
IR-02	10 Addressed	15 Partial	10 Addressed
BC-01	8 Addressed	12 Partial	8 Addressed
BC-02	8 Addressed	8 Addressed	8 Addressed
SDLC-01	8 Addressed	8 Addressed	8 Addressed
SDLC-02	8 Addressed	8 Addressed	8 Addressed
LOG-01	8 Addressed	8 Addressed	8 Addressed
SUP-01	8 Addressed	12 Addressed	8 Addressed
SUP-02	8 Addressed	8 Addressed	8 Addressed
SUP-03	9 Partial	6 Addressed	9 Partial
ASSUR-01	12 Partial	8 Addressed	8 Addressed
ASSUR-02	8 Addressed	8 Addressed	8 Addressed
ASSUR-03	12 Partial	8 Addressed	12 Partial
ASSUR-04	9 Partial	9 Partial	6 Addressed
AI-01	8 Addressed	8 Addressed	8 Addressed

4.2 High residual items

Vendor	Control	Coverage	L x I	Rating	Why
Greenhouse Software	IAM-04 Access review and timely termination	Not evidenced	4x5=20	Critical	The reviewed sources describe restricted production access and manager approval, but do not state a periodic access-review cadence or a timely termination/deprovisioning timeframe for vendor staff.
Atlassian	IAM-04 Access review and timely termination	Partial	3x5=15	High	Regular reviews and prompt revocation are stated, but no cadence or timeframe is given.
Atlassian	DAT-02 Data retention and deletion	Partial	3x5=15	High	The current DPA requires deletion after termination, but permits legal and standard backup/record-retention exceptions and does not state a fixed deletion timeframe; the project's Addressed threshold therefore is not met.
Greenhouse Software	IAM-02 Multi-factor authentication	Partial	3x5=15	High	MFA is not stated on the reviewed pages; Twilio is disclosed as the two-factor authentication provider, which indicates a feature exists.
Greenhouse Software	IR-02 Customer incident notification with a defined timeframe	Partial	3x5=15	High	Greenhouse states that significant-incident notification follows the timeframe in the customer license agreement, but the numeric timeframe is not public; the project therefore keeps this Partial.
Notion	DAT-02 Data retention and deletion	Partial	3x5=15	High	Deletion procedures and AI retention limits (30/60 days) are stated, but general customer-content retention periods are not.

4.3 Domain view

Domain (non-Addressed / total)	Atlassian	Greenhouse	Notion
Assurance	3 / 4	1 / 4	1 / 4
Business Continuity	0 / 2	1 / 2	0 / 2
Data Protection	1 / 5	1 / 5	2 / 5
Governance	0 / 2	0 / 2	0 / 2
Identity & Access	1 / 4	2 / 4	0 / 4
Incident Response	0 / 3	1 / 3	0 / 3
Secure Development	0 / 2	0 / 2	0 / 2
Third-Party Risk	1 / 3	0 / 3	1 / 3
Vulnerability Management	0 / 2	0 / 2	0 / 2

5. Vendor findings

5.1 Atlassian

Tier 1 (Critical). Use case: Jira / Confluence / Jira Service Management for engineering delivery and IT service management. Impact-weighted coverage 79.3%; 2 High residual item(s).

Strengths

- Contractual exhibit (effective 7 Oct 2025) states least privilege, MFA, AES-256/TLS 1.2+, quarterly DR tests validated by external auditors, environment separation and a supplier-risk framework, with numbered sections that make every claim citable.
- Public IAM reference architecture (1 Sep 2026) and built-in-controls guide describe customer-side SSO, MFA, SCIM and SIEM-integrated audit logging.
- Bug bounty (Bugcrowd), published advisories and bulletins, and a CVSS-based bugfix policy.

Gaps and caveats

- SOC 2 Type II reports listed are product-specific (Jira, Confluence). The FY26 report (1 Oct 2024 to 30 Sep 2025) was announced as due December 2025; no issuance notice was visible.
- No access-review cadence, no fixed incident-notification hours, no post-termination deletion period, no RTO/RPO values.
- Advanced identity controls depend on Atlassian Guard licensing (plan dependency).
- Least-privilege and environment-separation evidence rests on the contractual exhibit rather than on the migration-only white paper or on tenant isolation, which is a different control.

Recommended next steps

- Read the FY26 SOC 2 reports for every in-scope product; obtain bridge letter and FY27 timeline.
- Negotiate notification window and deletion timeframe; confirm Guard plan and cost.
- Request latest pentest executive summary (only an annual statement is public).

5.2 Greenhouse Software

Tier 2 (Important). Use case: Applicant tracking and onboarding for a multinational workforce. Impact-weighted coverage 77.6%; 2 High residual item(s).

Strengths

- Broadest independent artifact listing: SOC 2 Type 2 and SOC 1 Type 2 (2025), ISO 27001:2022, ISO 27701:2019, ISO 42001:2023 (announced Feb 2026), and three dated pentest artifacts (Q3 2025, Q1 2026, Q2 2026).
- 30 subprocessors with location and purpose, updated 1 Sep 2026; DPF transfer mechanisms stated.
- Prompt, transparent vulnerability response (CVE-2025-55182, Dec 2025).

Gaps and caveats

- Nine controls are reviewer-limited: the Access, Cloud Security, Continuity, Vendor Management, Secure Development, Incident and Privacy FAQs were indexed (251 answers) but not read.
- MFA enforcement, encryption parameters, RTO/RPO and access-review evidence are not visible on the pages reviewed.
- The 1 Sep 2026 'last updated' date applies to the subprocessor list only, not to the whole Trust Center.
- PCI evidence is a self-assessment questionnaire and SIG Lite is a self-attestation; neither is independent assurance.

Notable public events

- Klue third-party incident (announced 24 Jun 2026): attackers obtained credentials Klue used to connect to Greenhouse business systems on 11 Jun 2026; exposure limited to business contact data in sales/CRM systems; no candidate or hiring data; authorities notified; investigation ongoing. This is a realised supply-chain event and drives the +1 uplift on SUP-01.

Recommended next steps

- Request the Klue root-cause summary and integration-credential controls (rotation, scoping, monitoring).
- Read the seven FAQ sections and re-score; confirm MFA can be enforced for all users.
- Ask for the 2026 Onboarding pentest retest (last report Q3 2025) and SOC 2 period end date.

5.3 Notion

Tier 2 (Important). Use case: Company wiki and internal documentation workspace with AI features enabled. Impact-weighted coverage 86.2%; 1 High residual item(s).

Strengths

- 16 control categories published with parameters: TLS 1.2+, AES-256 including backups, customer-managed keys, access review at least quarterly, access removal within 24 hours, 72-hour standard breach notification, annual IR and BC/DR testing.
- Public HackerOne bug bounty; 2026 pentest reports (web, mobile, desktop, Calendar, Mail) and July 2026 CAIQ/VSA/HECVAT listed.
- Detailed AI governance controls including retention limits (30/60 days), kill switch and no-training commitments.

Gaps and caveats

- All reports are request-gated; statements are vendor-authored and unverified.
- ISO 27701, 27017 and 27018 are claimed in the header and security page, but only the ISO 27001 certificate and Statement of Applicability are listed as documents.
- General retention/deletion timeframes and a cross-border transfer mechanism are not stated; insurance evidence is dated 2025 and valid until November 2026.

- AI/LLM and search subprocessors increase fourth-party exposure; current Atlassian AI safeguards are now explicitly reviewed.

Recommended next steps

- Request SOC 2 report and ISO 27701/27018 certificates; confirm 72-hour notice meets client needs.
- Ask for deletion timeframe and transfer mechanism; request cyber-insurance certificate before November 2026 expiry.
- Review the AI-provider list and the no-training contractual terms.

6. Cross-vendor observations

- \textbf{Disclosure asymmetry.} Notion's Trust Center shows control-level detail on one page; Greenhouse and Atlassian expose FAQ counts (251 and 169) and gated documents. A reader comparing scores should distinguish public transparency from independent assurance.
- \textbf{Assurance artifacts are gated.} For all three vendors the SOC 2 report contents, audit period and exceptions are invisible. A listed report supports level 3 evidence of existence, not of effectiveness.
- \textbf{Time-bound artifacts.} Atlassian FY26 SOC 2 currency (unconfirmed), Greenhouse Onboarding pentest age (about 12 months), and Notion insurance evidence (expires November 2026) each need a diary date.
- \textbf{AI and fourth-party concentration.} LLM hosting providers appear in the subprocessor lists of Greenhouse (Anthropic, OpenAI) and Notion (a dozen providers). Client data flows to those providers under vendor-level contracts the client cannot audit directly. Only Greenhouse holds an independent AI management-system certificate (ISO 42001).
- \textbf{Binary features versus parameters.} Several 'has X' checklist ticks (annual pentest, DR plan, cyber insurance, centralised SSO) are workforce-level assertions. They were kept at evidence level 1 unless a parameter or artifact backed them.
- \textbf{Common contractual gaps.} Deletion timing remains a substantive contractual/ product-documentation gap where the public DPA does not give a fixed period; incident-notification and subprocessor-notice terms are now evidenced for Atlassian.

7. Sensitivity analysis

The ranking of vendors should hold under reasonable changes to the assumptions. The table shows the number of High or Critical residual items (out of 27) under alternative treatments.

Vendor	Base case	Limited favourable	Limited adverse	No adverse uplift
Greenhouse Software	3	3	3	3
Atlassian	2	2	2	2
Notion	1	1	1	1

No vendor/control row remains reviewer-limited in this updated run, so the two limited-source sensitivity columns now equal the base case. Remaining sensitivity is driven by substantive control uncertainty and the documented Klue adverse-event uplift.

8. Limitations, bias and independence

- \textbf{Public evidence only.} Gated audit reports remain listed rather than reviewed; Atlassian's current public DPA was reviewed. Nothing here is an audit, certification opinion, penetration test or legal advice.
- \textbf{Remaining source limitations.} Gated audit reports and some vendor documentation remain unavailable without access requests. No assessment row remains reviewer-limited after the current source review; remaining gaps are substantive (for example, Greenhouse IAM-04 and Atlassian DAT-02).
- \textbf{Vendor-authored statements are unverified.} Even level 2 evidence is a claim by the vendor. Independent verification needs the SOC 2 report or a technical test.
- \textbf{Point in time.} Trust Centers change. Findings in this updated run use the original 24 September 2026 snapshot plus sources reviewed on 4 October 2026. Sources are cited by URL and section; no archived snapshots were taken (recommended improvement).
- \textbf{Assumptions drive the numbers.} Impact values, tier factors, likelihood mapping and bands are project-defined and documented in Section~3; they are not ISO or NIST thresholds.
- \textbf{Scope gaps.} FOCI and provenance (SP 1326) were not assessed; nor were concentration risk, financial health, litigation, breach history beyond vendor announcements, or technical attack-surface signals.
- \textbf{Independence.} Findings were derived from cited public text; readers should apply their own judgement and verify anything material before relying on it.

9. Risk treatment plan and monitoring

9.1 Evaluation criteria (ISO 31000 risk evaluation)

Rating	Proposed treatment rule (project assumption)
Critical	Do not onboard or renew without executive-approved treatment plan and compensating controls.
High	Treatment plan with owner and date before onboarding; renewal only if closed or formally accepted by the business owner.
Medium	Accept with monitoring; validate at next scheduled review.
Low	Accept.

9.2 Prioritised actions

#	Action	Vendors	Treatment	Timing
1	Obtain and read SOC 2 Type II reports and bridge letters; record scope, period, exceptions and complementary user-entity controls	All (Atlassian first)	Mitigate – validate	30 days
2	Contract: incident-notification hours, post-termination deletion timeframe, sub-processor change notice and objection right	All	Mitigate – contract	Before signature/ renewal
3	Greenhouse: Klue root-cause summary; integration-credential rotation and scoping; confirm MFA enforcement	Greenhouse	Mitigate – validate	30 days
4	Retrieve and read vendor FAQ sections marked reviewer-limited, then re-score	Greenhouse, Atlassian	Reduce uncertainty	30 days
5	Request pentest executive summaries or letters (Atlassian) and 2026 Onboarding retest (Greenhouse)	Atlassian, Greenhouse	Mitigate – validate	60 days
6	Request RTO/RPO values and last DR test evidence	All	Mitigate – validate	60 days
7	Confirm data-residency options and transfer mechanism; verify DPF registry entries	All	Mitigate – contract	60 days
8	Verify ISO 27001:2022 certificate scope and expiry with the certification body; request ISO 27701/27018 certificates where claimed	All	Mitigate – validate	60 days

#	Action	Vendors	Treatment	Timing
9	Client-side configuration baseline: enforce SSO and MFA, restrict SMS, restrict marketplace apps and AI features, enable audit-log export to SIEM	All	Mitigate – configure	90 days
10	Request cyber-insurance certificates and note renewal dates	All	Transfer – verify	90 days
11	Enhanced due diligence for Atlassian (Tier 1): FOCI, provenance, questionnaire, technical review of Marketplace app governance	Atlassian	Reduce uncertainty	90 days

9.3 Monitoring triggers

- Annual re-assessment (Tier 1 vendors: every 6 months for Trust Center changes).
- Subscribe to each Trust Center's update feed; review new incident announcements within 5 working days.
- Date-driven: Atlassian FY27 SOC 2 period ends 30 Sep 2026; Notion insurance evidence expires Nov 2026; Greenhouse Klue investigation update; Greenhouse Onboarding pentest renewal.
- Event-driven: security incident, subprocessor or AI-provider change, acquisition, new product in scope, loss of a certification.

10. Recommended further improvements to this project

- \textbf{Archive evidence.} Save dated PDF/HTML snapshots of each source page (or use a web-archive service) so findings survive Trust Center changes.
- \textbf{Retrieve remaining gated assurance artifacts} (SOC 2 reports, bridge letters and any restricted policies) and re-run the scoring; the current public-source review no longer has reviewer-limited assessment rows.
- \textbf{Add enhanced due diligence inputs}: FOCI/ownership, provenance, breach history in public databases, external attack-surface scoring, and the actual SOC 2 reports.
- \textbf{Second-reviewer check.} Have a second analyst score a sample of rows blind to measure agreement.
- \textbf{Weighting by client data flows} (which module, which data class) instead of one impact value per control.
- \textbf{Track over time.} Store each assessment run so that changes between quarters are visible.
- \textbf{Automate change detection} on Trust Center pages and announcements to trigger re-assessment.

A. Control catalogue and framework mapping

ID	Requirement	I	ISO 27001:2022	CSF 2.0	SP 800-53r5	SOC 2	SP 1326
GOV-01	Information security governance / ISMS	4	Clauses 4-10; A.5.1; A.5.2	GV.PO-01; GV.RR-01	PM-1; PM-9; PL-1	CC1.1-CC1.5; CC2.1	Foundational cyber practices
IAM-01	SSO / centralised identity management	5	A.5.16; A.5.17; A.5.15	PR.AA-01; PR.AA-02	IA-2; IA-4; IA-8; AC-2	CC6.1	Foundational cyber practices
IAM-02	Multi-factor authentication	5	A.8.5	PR.AA-03	IA-2(1); IA-2(2)	CC6.1	Foundational cyber practices
IAM-03	Least privilege / RBAC	5	A.5.15; A.8.2; A.8.3	PR.AA-05	AC-3; AC-6	CC6.1-CC6.3	Foundational cyber practices
IAM-04	Access review and timely termination	5	A.5.18; A.6.5	PR.AA-05	AC-2; PS-4; PS-5	CC6.2; CC6.3	Foundational cyber practices
DAT-01	Encryption in transit and at rest	5	A.8.24	PR.DS-01; PR.DS-02	SC-8; SC-13; SC-28	CC6.1; CC6.7	Foundational cyber practices
DAT-02	Data retention and deletion	5	A.8.10; A.5.33	ID.AM-08; PR.DS-01	SI-12; MP-6	C1.2; P4.1-P4.3	Foundational cyber practices
DAT-03	Subprocessor transparency	5	A.5.19; A.5.21	GV.SC-04	SR-3; SA-9	CC9.2	Supply chain tiers
DAT-04	Data processing agreement	5	A.5.20; A.5.34	GV.SC-05	SA-4; SR-5	CC9.2; P6.1	Foundational cyber practices
DAT-05	Data residency and international transfer mechanism	4	A.5.34; A.5.31	GV.OC-03; ID.AM-08	SA-9(5); PT-3	P6.1-P6.6	Foundational cyber practices
VUL-01	Independent penetration testing	4	A.8.8; A.8.29	ID.RA-01; ID.IM-02	CA-8; RA-5	CC4.1; CC7.1	Foundational cyber practices
VUL-02	Vulnerability disclosure / bug bounty	4	A.8.8	ID.RA-08	RA-5(11)	CC7.1	Foundational cyber practices
IR-01	Incident management process	5	A.5.24-A.5.28	RS.MA-01; RS.AN-03; RC.RP-01	IR-1; IR-4; IR-8	CC7.3-CC7.5	Foundational cyber practices
IR-02	Customer incident notification with a defined timeframe	5	A.5.26; A.5.34	RS.CO-02	IR-6	CC7.4; CC2.3	Foundational cyber practices
BC-01	Disaster recovery	4	A.5.29; A.5.30; A.8.13; A.8.14	RC.RP-01; PR.IR-03	CP-2; CP-9; CP-10	A1.2; A1.3; CC9.1	Resilience

ID	Requirement	I	ISO 27001:2022	CSF 2.0	SP 800-53r5	SOC 2	SP 1326
BC-02	Availability and status transparency	4	A.5.30	RC.CO-03	CP-2	A1.1; A1.2	Resilience
SDLC-01	Secure development practices	4	A.8.25-A.8.29	PR.PS-06	SA-3; SA-8; SA-11; SA-15	CC8.1	Foundational cyber practices
SDLC-02	Separation of development, test and production	4	A.8.31	PR.IR-01	SA-3(1); CM-4	CC8.1	Foundational cyber practices
LOG-01	Security logging and monitoring	4	A.8.15; A.8.16	DE.CM-01; DE.AE-02	AU-2; AU-6; SI-4	CC7.2	Foundational cyber practices
SUP-01	Supplier and subservice oversight	4	A.5.19-A.5.22	GV.SC-06; GV.SC-07	SR-6; SA-9	CC9.2	Supply chain tiers
SUP-02	Critical infrastructure and service dependency transparency	4	A.5.21	GV.SC-04; ID.AM-04	SR-3; SA-9	CC9.2	Supply chain tiers
SUP-03	Cyber insurance / financial backstop	3	Not mapped (contractual risk transfer)	GV.RM-04	Not mapped	Not mapped	Resilience
ASSUR-01	SOC 2 Type II	4	A.5.35	GV.OV-03; ID.IM-01	CA-2	All (attestation)	Foundational cyber practices
ASSUR-02	ISO/IEC 27001 certification	4	Clauses 9.2; 9.3; A.5.35	GV.OV-03	CA-2	Not mapped	Foundational cyber practices
ASSUR-03	Privacy assurance (ISO/IEC 27701, 27018 or equivalent)	4	A.5.34	GV.OC-03	PT family	P-series	Foundational cyber practices
ASSUR-04	Evidence currency	3	Not mapped (methodology)	Not mapped	Not mapped	Not mapped	Foundational cyber practices
AI-01	AI governance and use of customer data in AI features	4	A.5.1; A.5.19 (with ISO/IEC 42001)	GV.RM-01; GV.SC-06	SR-3; PM-9	CC1.x; C1.1	Supply chain tiers

Mappings are indicative cross-references prepared for this project. They are not official crosswalks and standard text is not reproduced (ISO texts are paywalled). Impact (I) is 1–5.

B. Full assessment matrix

B.1 Atlassian

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
GOV-01	Addressed	3	2	4	8	Medium	EV-ATL-01, EV-ATL-02, EV-ATL-22	ISO 27001 and SOC 2 Type II artifacts are listed and the contractual exhibit describes an executive-level programme aligned to ISO 27001, SOC 2 and NIST 800-53.
IAM-01	Addressed	2	2	5	10	Mediun	EV-ATL-05, EV-ATL-06, EV-ATL-11	Workforce SSO is contractual; customer SSO and SCIM are described in the IAM white paper. Advanced identity controls depend on Atlassian Guard licensing.
IAM-02	Addressed	2	2	5	10	Medium	EV-ATL-05, EV-ATL-10, EV-ATL-11	MFA is contractual for staff and appears in the customer-side authentication layer of the IAM white paper (plan dependent).
IAM-03	Addressed	2	2	5	10	Mediun	EV-ATL-10, EV-ATL-05	Vendor-staff least privilege and RBAC on a need-to-know basis are stated in the contractual exhibit.
IAM-04	Partial	2	3	5	15	High	EV-ATL-10, EV-ATL-12	Regular reviews and prompt revocation are stated, but no cadence or timeframe is given.
DAT-01	Addressed	2	2	5	10	Mediun	EV-ATL-13, EV-ATL-23	AES-256 at rest, TLS 1.2+ with PFS in transit and cloud-provider KMS are stated.
DAT-02	Partial	2	3	5	15	High	EV-ATL-14, EV-ATL-26	The current DPA requires deletion after termination, but permits legal and standard backup/record-retention exceptions and does not state a fixed deletion timeframe; the project's Addressed threshold therefore is not met.
DAT-03	Addressed	2	2	5	10	Mediun	EV-ATL-25, EV-ATL-27	The current DPA provides an up-to-date subprocessor list, subscription-based notice and a 30-day notice period for new subprocessors; the current list is publicly available.
DAT-04	Addressed	2	2	5	10	Medium	EV-ATL-04	A DPA and a data-transfer impact assessment are linked.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
DAT-05	Addressed	2	2	4	8	Medium	EV-ATL-01, EV-ATL-28, EV-ATL-29	Atlassian documents selectable data-residency locations mapped to AWS regions and the DPA provides EU SCCs and the EU-U.S. Data Privacy Framework as transfer mechanisms, meeting the project's Addressed definition.
VUL-01	Addressed	2	2	4	8	Medium	EV-ATL-04, EV-ATL-15	Annual penetration testing is a contractual statement; no dated third-party report or letter is publicly listed.
VUL-02	Addressed	2	2	4	8	Medium	EV-ATL-04, EV-ATL-15	A Bugcrowd programme, published advisories/bulletins and a CVSS-based bugfix policy are stated.
IR-01	Addressed	2	2	5	10	Medium	EV-ATL-16	Incident plans, cross-functional teams, testing, annual review and root-cause analysis are stated.
IR-02	Addressed	2	2	5	10	Medium	EV-ATL-16, EV-ATL-24	The current DPA states customer notification without undue delay and, where feasible, no later than 72 hours after Atlassian becomes aware of a Security Incident.
BC-01	Addressed	2	2	4	8	Medium	EV-ATL-17	BC/DR plans with RTO/RPO defined, daily backups, annual restore tests and quarterly DR tests validated by external auditors.
BC-02	Addressed	2	2	4	8	Medium	EV-ATL-04, EV-ATL-16	A public status page is linked in the Trust Center and contractual exhibit.
SDLC-01	Addressed	2	2	4	8	Medium	EV-ATL-18	Secure SDLC, peer review, mandatory tests, dependency scanning and developer training are stated.
SDLC-02	Addressed	2	2	4	8	Medium	EV-ATL-19	Environment separation and no production data in non-production are explicitly stated.
LOG-01	Addressed	2	2	4	8	Medium	EV-ATL-21, EV-ATL-05	Centralised logging, monitoring of audit logs and SIEM-integrated customer audit logging are described.
SUP-01	Addressed	2	2	4	8	Medium	EV-ATL-20	A formal TPRM framework with onboarding and periodic assessments and annual review of supplier audit reports is described.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
SUP-02	Addressed	2	2	4	8	Medium	EV-ATL-20, EV-ATL-27	The current subprocessor disclosure identifies infrastructure/service dependencies and the DPA links the maintained list; AWS and other infrastructure providers can be identified publicly.
SUP-03	Partial	1	3	3	9	Mediur	EV-ATL-04	Cyber insurance is asserted on the checklist; no certificate or period is shown.
ASSUR-01	Partial	3	3	4	12	Medium	EV-ATL-02, EV-ATL-03	SOC 2 Type II reports are listed for Jira and Confluence only; scope for other products is not visible and currency of the FY26 report is unconfirmed.
ASSUR-02	Addressed	3	2	4	8	Mediur	EV-ATL-02	ISO 27001:2022 certificate listed.
ASSUR-03	Partial	3	3	4	12	Medium	EV-ATL-01	ISO 27018 and DPF are shown, but no ISO 27701 certificate appears in the reviewed sources.
ASSUR-04	Partial	2	3	3	9	Mediur	EV-ATL-03, EV-ATL-05, EV-ATL-06	Announcements run to 1 Sep 2026 and the contractual exhibit is dated Oct 2025, but the previous SOC 2 report was stated valid only to end-2025 and no issuance notice for FY26 is visible.
AI-01	Addressed	2	2	4	8	Medium	EV-ATL-09, EV-ATL-30, EV-ATL-31	Current Atlassian AI documentation provides specific controls and parameters: third-party LLM providers are under zero-data-retention commitments, customer data is not used by those providers to train/improve models, and feature-level permissions/retention safeguards are documented. This meets the project's specific-control-set threshold.

B.2 Greenhouse Software

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
GOV-01	Addressed	3	2	4	8	Medium	EV-GH-02, EV-GH-12	ISO 27001:2022 and SOC 2 Type II attestations are listed and a security programme is described.
IAM-01	Addressed	2	2	5	10	Mediur	EV-GH-10	Customer-facing SSO and SCIM provisioning are stated on the vendor page.
IAM-02	Partial	1	3	5	15	High	EV-GH-05	MFA is not stated on the reviewed pages; Twilio is disclosed as the two-factor authentication provider, which indicates a feature exists.
IAM-03	Addressed	2	2	5	10	Mediur	EV-GH-10, EV-GH-16	Greenhouse states that customer-data access is restricted to employees who require it for their roles and follows least privilege; the support overview also documents tightly restricted production access.
IAM-04	Not evidenced	2	4	5	20	Critical	EV-GH-04, EV-GH-16	The reviewed sources describe restricted production access and manager approval, but do not state a periodic access-review cadence or a timely termination/deprovisioning timeframe for vendor staff.
DAT-01	Addressed	2	2	5	10	Mediur	EV-GH-17	Greenhouse explicitly states TLS 1.2 or higher for data in transit and AES-256 for data at rest, meeting the project definition for Addressed.
DAT-02	Addressed	2	2	5	10	Medium	EV-GH-18	Greenhouse documents deletion from production and a 30-day backup/S3-version retention window followed by complete purge on day 31, providing a defined deletion timeframe.
DAT-03	Addressed	2	2	5	10	Mediur	EV-GH-05	30 subprocessors are listed with location and purpose; page shows a 1 Sep 2026 update.
DAT-04	Addressed	2	2	5	10	Medium	EV-GH-04	A standard DPA is linked from the Trust Center.
DAT-05	Partial	2	3	4	12	Mediur	EV-GH-05, EV-GH-14	Transfer mechanisms (EU-US, UK and Swiss DPF) and hosting countries (US, Germany, Australia) are stated; residency options for customer data are not.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
VUL-01	Addressed	3	2	4	8	Medium	EV-GH-03, EV-GH-11	Three dated third-party pentest artifacts are listed (Q3 2025, Q1 2026, Q2 2026).
VUL-02	Addressed	2	2	4	8	Mediur	EV-GH-04	A HackerOne programme is linked.
IR-01	Addressed	2	2	5	10	Medium	EV-GH-10, EV-GH-13, EV-GH-06, EV-GH-07	24/7/365 SOC is stated, post-mortem process asserted, and two public disclosures (Dec 2025, Jun 2026) show the process operating.
IR-02	Partial	2	3	5	15	High	EV-GH-22	Greenhouse states that significant-incident notification follows the timeframe in the customer license agreement, but the numeric timeframe is not public; the project therefore keeps this Partial.
BC-01	Partial	1	3	4	12	Medium	EV-GH-04, EV-GH-13	The reviewed Trust Center and security page establish a DR plan, routine backups and DR testing, but do not provide a sufficiently specific testing cadence or RTO/RPO values for an Addressed rating.
BC-02	Addressed	2	2	4	8	Mediur	EV-GH-04, EV-GH-13	A public status page is linked and uptime SLAs are mentioned.
SDLC-01	Addressed	2	2	4	8	Medium	EV-GH-19	Greenhouse documents peer code review, security/code-quality scanning, test plans for higher-risk changes and testing before release, satisfying the project definition of specific secure-SDLC practices.
SDLC-02	Addressed	2	2	4	8	Mediur	EV-GH-20	Greenhouse explicitly states changes are tested in a non-production environment before production release, satisfying the project's environment-separation criterion.
LOG-01	Addressed	2	2	4	8	Medium	EV-GH-10	24/7/365 SOC is stated and an audit log API is offered to customers.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
SUP-01	Addressed	2	3	4	12	Mediun	EV-GH-21	Greenhouse states it performs annual security reviews of all data subprocessors and requires them to sign DPAs, which is evidence of a supplier-assessment and review process. The separate Klue event remains an adverse-event consideration. [adverse +1]
SUP-02	Addressed	2	2	4	8	Medium	EV-GH-05	Hosting (AWS by region), CDN, datastore (MongoDB), analytics and AI providers are identifiable.
SUP-03	Addressed	2	2	3	6	Mediun	EV-GH-04	A cyber-insurance certificate for 2025-2026 is listed.
ASSUR-01	Addressed	3	2	4	8	Medium	EV-GH-02	A company-level 2025 SOC 2 Type 2 report is listed.
ASSUR-02	Addressed	3	2	4	8	Mediun	EV-GH-02, EV-GH-12	ISO 27001:2022 certificate listed (edition stated on vendor page).
ASSUR-03	Addressed	3	2	4	8	Medium	EV-GH-02, EV-GH-12	ISO 27701:2019 certificate listed.
ASSUR-04	Partial	2	3	3	9	Mediun	EV-GH-02, EV-GH-03, EV-GH-08	Pentests (Q1/Q2 2026) and ISO 42001 (Feb 2026) are recent, but the SOC 2 period is not visible and the 1 Sep 2026 date applies to the subprocessor list, not the whole Trust Center.
AI-01	Addressed	3	2	4	8	Medium	EV-GH-05, EV-GH-08, EV-GH-09	ISO/IEC 42001:2023 certification is independent evidence of an AI management system; AI providers (Anthropic, OpenAI) are disclosed with purpose.

B.3 Notion

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
GOV-01	Addressed	3	2	4	8	Medium	EV-NOT-01, EV-NOT-02	SOC 2 Type II and ISO 27001 are listed and about 20 governance policies are inventoried.
IAM-01	Addressed	2	2	5	10	Mediun	EV-NOT-03	SAML 2.0 SSO with SSO-only enforcement and SCIM provisioning are stated.
IAM-02	Addressed	2	2	5	10	Medium	EV-NOT-03	Two-step verification on all plans with TOTP, passkeys and SMS.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
IAM-03	Addressed	2	2	5	10	Medium	EV-NOT-03	RBAC for customers and least privilege with documented justification for staff are stated.
IAM-04	Addressed	2	2	5	10	Medium	EV-NOT-03	Reviews at least quarterly and access terminated within 24 hours of the last working day.
DAT-01	Addressed	2	2	5	10	Medium	EV-NOT-04	TLS 1.2+, AES-256 at rest including backups and customer-managed keys via AWS KMS.
DAT-02	Partial	2	3	5	15	High	EV-NOT-05	Deletion procedures and AI retention limits (30/60 days) are stated, but general customer-content retention periods are not.
DAT-03	Addressed	2	2	5	10	Medium	EV-NOT-11	26 subprocessors with purpose and location.
DAT-04	Addressed	2	2	5	10	Medium	EV-NOT-01	DPA linked from the Trust Center.
DAT-05	Partial	2	3	4	12	Medium	EV-NOT-11, EV-NOT-04	Hosting regions (USA, EU, Korea, Japan) are named, but no transfer mechanism (DPF/SCCs) is stated in reviewed pages.
VUL-01	Addressed	3	2	4	8	Medium	EV-NOT-02, EV-NOT-08	Annual third-party grey-box testing plus 2026 pentest reports and retests are listed.
VUL-02	Addressed	2	2	4	8	Medium	EV-NOT-08	Public HackerOne bug bounty and responsible disclosure policy.
IR-01	Addressed	2	2	5	10	Medium	EV-NOT-06	24/7/365 on-call team, approved IR plan, annual testing and post-incident review.
IR-02	Addressed	2	2	5	10	Medium	EV-NOT-06, EV-NOT-15	The current Notion Trust Center explicitly states standard breach notification within 72 hours; the DPA remains a separate contractual artifact, but the project criterion itself is evidenced.
BC-01	Addressed	2	2	4	8	Medium	EV-NOT-07	DR plan, cross-region backups and annual tested BC/DR with documented results.
BC-02	Addressed	2	2	4	8	Medium	EV-NOT-07, EV-NOT-01	99.9% availability commitment with public uptime history.
SDLC-01	Addressed	2	2	4	8	Medium	EV-NOT-08	SDLC with threat modelling, SAST per PR, SCA, mandatory review and training.

Ctrl.	Coverage	Ev	L	I	Score	Rating	Evidence IDs	Rationale / flag
SDLC-02	Addressed	2	2	4	8	Medium	EV-NOT-09	Explicit separation of development, test and production; no production data in non-production without coordination.
LOG-01	Addressed	2	2	4	8	Medium	EV-NOT-12	Audit logging, 24/7/365 monitoring, SIEM and privileged-access tracking.
SUP-01	Addressed	2	2	4	8	Medium	EV-NOT-10	Criticality-based vendor assessments and annual subprocessor reviews.
SUP-02	Addressed	2	2	4	8	Medium	EV-NOT-11	Hosting, CDN, streaming, logging and MFA providers are named.
SUP-03	Partial	1	3	3	9	Medium	EV-NOT-02	A 2025 evidence of insurance valid until November 2026 is listed; cyber coverage is not confirmed.
ASSUR-01	Addressed	3	2	4	8	Medium	EV-NOT-01, EV-NOT-02	SOC 2 Type II and SOC 3 reports are listed.
ASSUR-02	Addressed	3	2	4	8	Medium	EV-NOT-02	ISO 27001 certificate and Statement of Applicability are listed.
ASSUR-03	Partial	1	3	4	12	Medium	EV-NOT-01, EV-NOT-14	ISO 27701, 27017 and 27018 are claimed but no certificates are listed as documents.
ASSUR-04	Addressed	2	2	3	6	Medium	EV-NOT-02	CAIQ, VSA and HECVAT are dated July 2026, 2026 pentest reports are listed and insurance runs to November 2026.
AI-01	Addressed	2	2	4	8	Medium	EV-NOT-13, EV-NOT-11	A specific AI control set with retention parameters and a kill switch is stated; no independent AI certification is listed.

C. Evidence register

Findings are paraphrased from public pages retrieved on 24 September 2026. Source IDs resolve in Appendix D. Level: 3 independent, 2 vendor-specific, 1 assertion.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
GH-01	GH-01	Badges section	Badges shown for ISO 42001, ISO 27001, ISO 27701, SOC 1 Type II, SOC 2 Type II, GDPR, CCPA, PCI, SIG and the EU-US, UK-US and Swiss-US Data Privacy Framework.	1	Badges are vendor-placed; underlying artifacts are separate.
GH-02	GH-01	Featured Documents	Listed artifacts: 2025 SOC 2 Type 2 report, 2025 SOC 1 Type 2 report, ISO 27001 and 27701 certificate, ISO 42001:2023 certificate.	3	Contents gated; audit period, scope and exceptions not visible.
GH-03	GH-01	Featured Documents	Dated penetration-test artifacts listed: Q2 2026 Recruiting report, Q3 2025 Onboarding report, Q1 2026 external network customer letter.	3	Findings not reviewed; the Onboarding report is about 12 months old and a 2026 retest is not visible.
GH-04	GH-01	Quick Summary	Checklist items asserted: annual third-party audits, MDM programme, annual third-party pentest, DR plan, subprocessor list, cyber insurance, DPA, bug bounty/VDP via HackerOne, API, centralised SSO for employee access, status page, privacy policy.	1	Checklist only; the SSO item refers to vendor workforce access, not the customer-facing feature.
GH-05	GH-01	Subprocessors (30)	30 subprocessors with location and purpose, including AWS (US, Germany, Australia) for hosting, Cloudflare, Datadog, MongoDB (Sourcing Automation datastore), Twilio (two-factor authentication and email), Snowflake, and Anthropic and OpenAI (hosting large language models for AI features and internal operations). Page states last updated 1 Sep 2026.	2	Change-notification terms sit in the DPA (not reviewed).

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
GH-06	GH-01	Announcemen 2026-06-24	Third-party incident at supplier Klue: attackers obtained credentials Klue used to connect to certain Greenhouse business systems; access occurred 11 Jun 2026, was limited to Klue's integration and to business contact data in sales/CRM systems; no product, hiring or candidate data affected; no modification or deletion identified; data protection authorities notified; investigation with Klue continuing.	2	Vendor-authored, not independently verified; root cause and remediation not yet published in the reviewed page.
GH-07	GH-01	Announcement 2025-12-17	Response to CVE-2025-55182: virtual patch deployed to the WAF on the day of the 3 Dec 2025 advisory, vulnerable features confirmed unused, dependencies upgraded and validated, WAF rules retained.	2	Vendor-authored.
GH-08	GH-01	Announcemen 2026-02-26	ISO/IEC 42001:2023 certification announced.	3	Certificate scope not reviewed.
GH-09	GH-01	Knowledge Base FAQ index	251 FAQ answers indexed by category, including Access Management (15), Application and Data Security (36), Continuity and DR (11), Incident Management (10), Secure Development (1), Vendor Management (4), Security Governance (13), Privacy (31), Artificial Intelligence (30).	1	FAQ bodies were not retrieved: this is a REVIEWER LIMITATION, not proof of absence.
GH-10	GH-02	Software security section	Product security features stated: single sign-on, SCIM user provisioning, audit log API, permissions approvals, and a dedicated security team with a 24/7/365 security operations centre.	2	No plan/tier detail.
GH-11	GH-02	Security programme	Annual third-party penetration testing, bug bounty, security embedded throughout development, and encryption in transit and at rest are stated.	1	No protocol versions, algorithms or key management stated.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
GH-12	GH-02	Global compliance standards	Annual SOC 1 Type 2 and SOC 2 Type 2 audits; certified to ISO 27001:2022, ISO 27701:2019 and ISO 42001:2023; PCI DSS, GDPR, CCPA/CPRA listed.	2	Edition statement (27001:2022) resolves the stale 2013 wording in S-GH-03.
GH-13	GH-02	Reliable platform performance	Routine backups and disaster-recovery tests, incident response and post-mortem processes, AWS-based multi-tier network, and uptime SLAs are stated.	1	No RTO/RPO, test dates or SLA percentage.
GH-14	GH-02	Comprehensiv data protection	Cross-border transfers are covered by the EU-US DPF, UK Extension and Swiss-US DPF.	2	DPF registry entry not independently checked in this review.
GH-15	GH-03	Security overview (excerpt)	Uploaded files are stored in Amazon S3 encrypted at rest; virtual infrastructure runs in an AWS VPC; card data is handled through a PCI Level 1 processor SDK; the company completes a PCI self-assessment questionnaire.	1	Excerpt only; also cites older ISO editions (stale). PCI SAQ is self-attestation, not a QSA report.
ATL-01	ATL-01	Badges section	Badges shown for SOC 2 Type II, ISO 27001, GDPR, ISO 27018, FedRAMP, EU-US DPF, TISAX, VPAT, SOC 1 Type II and GovRAMP.	1	Badges are vendor-placed.
ATL-02	ATL-01	Featured Documents	Listed artifacts: Jira/JSM/Confluence SOC 1 Type 2 report, Jira SOC 2 Type 2 + HIPAA report, Confluence SOC 2 Type 2 + HIPAA report, C5 assessment letter, ISO 27001 certificate (2022 edition badge).	3	SOC 2 reports are product-specific; other products are not shown. Contents gated.
ATL-03	ATL-01	Announcemen 2025-11-20	FY26 SOC 2 Type 2 reports cover 1 Oct 2024 to 30 Sep 2025, expected December 2025 with bridge letters in early 2026; the previous report and bridge letter were stated valid only through end of 2025.	3	No later announcement confirms issuance; the FY27 period ends 30 Sep 2026.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
ATL-04	ATL-01	Quick Summary	Checklist items asserted: annual third-party audits, MDM programme, annual third-party pentest, DR plan, subprocessor list, cyber insurance, DPA, bug bounty (Bugcrowd), deletion on request, API, centralised SSO for employee access, status page, privacy policy.	1	Checklist only.
ATL-05	ATL-01	Announcement 2026-09-01	IAM reference architecture white paper covering five layers: IdP integration, SCIM provisioning and domain verification; SSO and MFA with external-user policies; organisation and app-level access control; non-human identity governance; SIEM-integrated audit logging. Built on Atlassian Guard.	2	Announcement summary only; white paper not read; Guard is a separately licensed capability (plan dependency).
ATL-06	ATL-01	Announcement 2026-07-03	Guide to built-in security controls across Cloud Platform, Guard Standard and Guard Premium plans, including SSO, audit logging and content scanning, under a shared responsibility model.	2	Announcement summary only.
ATL-07	ATL-01	Announcement 2026-08-19	Migration Assistant white paper: encryption in transit and at rest, tenant isolation, least-privilege operator access, retention and disposal, data residency, sub-processors and incident notification, described for the Data Center-to-cloud migration pipeline.	1	Scope is the migration pipeline only; it must not be generalised to the whole platform.
ATL-08	ATL-01	Knowledge Base FAQ index	169 FAQ answers indexed, including Access Management (18), Encryption (7), Incident Management (8), Continuity and DR (4), Secure Development (2), Vendor Management (7), Security Governance (4), Artificial Intelligence (34).	1	FAQ bodies not retrieved: REVIEWER LIMITATION.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
ATL-09	ATL-01	Announcemen 2026-02 to 2026-06	AI-related white papers: Rovo secure AI architecture v2 (Jun 2026), OWASP Top 10 for LLM mitigations (Mar 2026), Rovo MCP server security (Feb 2026), Loom AI overview (May 2026, zero retention by sub-processors stated); Data protection, isolation and access white paper (Feb 2026); DORA guidance page.	2	Summaries only; no independent AI management-system certification listed.
ATL-10	ATL-03	Section 1 Access Control	Staff access follows least privilege and strict RBAC on a need-to-know basis (1.3, 1.4); MFA required on higher-tier services (1.2, 1.7); management approval before access and regular access-rights review (1.6); dormant accounts removed and access revoked promptly through automated and regular reviews (1.9).	2	No review cadence or revocation timeframe stated.
ATL-11	ATL-03	Section 7 Identification and Authentication	Workforce SSO through the directory (7.1); MFA for VPN and SSO application launch (7.2); NIST 800-63B-aligned password policy (7.3); automatic sync between HR and identity systems (7.5).	2	Applies to Atlassian workforce.
ATL-12	ATL-03	Section 14.4 Personnel security	Role changes and terminations trigger automatic de-provisioning and exit checklists.	2	No timeframe stated.
ATL-13	ATL-03	Sections 18.2 and 10.3	Customer data encrypted at rest with AES-256 and in transit with TLS 1.2+ with Perfect Forward Secrecy; full-disk encryption on data drives.	2	Key management detail comes from S-ATL-02 (cloud-provider KMS).
ATL-14	ATL-03	Sections 15.3, 19.1	Retention and destruction standards exist for personal data; disposal aims for irrecoverable data after sanitisation; deletion on request is asserted in S-ATL-01.	2	No retention periods or post-termination deletion timeframe stated.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
ATL-15	ATL-03	Sections 4.7-4.9, 16.3	Annual penetration testing of cloud and software products, bug-bounty programmes, continuous vulnerability scanning with CVSS-based remediation per a published bugfix policy, and annual security testing.	2	Test reports are not listed publicly; 'third-party' wording comes from S-ATL-01 only.
ATL-16	ATL-03	Section 8 Security Incident Response	Incident response plans, cross-functional teams, regular testing, annual review, post-incident root-cause analysis for high-severity incidents, published status page, and customer notification without undue delay per the DPA.	2	No numeric notification timeframe.
ATL-17	ATL-03	Sections 6 and 9 Contingency Planning	BC/DR plans with defined RTO and RPO (values not published), daily backups, annual restoration testing, quarterly DR tests validated by external auditors, cross-datacentre redundancy.	2	RTO/RPO values not public.
ATL-18	ATL-03	Sections 17, 5, 2.8	Agile secure SDLC; peer-reviewed pull requests and mandatory automated tests before merge; segregated change duties; scanning of third-party libraries; annual secure-development training.	2	Policy-level; no metrics.
ATL-19	ATL-03	Sections 18.3, 18.8, 19.2, 19.8	Environment separation limits connectivity between production and non-production; production data is not used in non-production; customer data is logically segregated from other customers.	2	Directly evidences dev/test/prod separation, which is distinct from tenant isolation between customers.
ATL-20	ATL-03	Section 20 Supply Chain Risk Management	Formal third-party risk framework: pre-onboarding and periodic supplier risk assessments, supplier inventory with ownership and risk levels, annual review of supplier audit reports such as SOC 2; AWS and Microsoft Azure named as infrastructure sub-processors (10.1).	2	Full sub-processor list was not retrieved.
ATL-21	ATL-03	Sections 3, 19.3-19.4	Logging standards, centralised read-only logs, monitoring for unusual activity, and retained logs of staff access to customer data.	2	No 24/7 coverage statement in the reviewed page.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
ATL-22	ATL-03	Introduction, Sections 4.4-4.5, 13	Executive-level security programme aligned to ISO 27001, SOC 2 and NIST 800-53; annual internal and independent external audits.	2	Alignment claims, not certification.
ATL-23	ATL-02	Encryption and Backups (excerpt)	TLS 1.2+ with PFS in transit; AES-256 at rest on listed products; key management via the underlying cloud provider's KMS with assigned key owners; automated daily database snapshots retained 30 days.	2	Excerpt only.
NOT-01	NOT-01	Header summary	Annual third-party audits listed: SOC 2 Type II, ISO 27001/27017/27018/27701, HIPAA, BSI C5; annual third-party penetration testing; HackerOne bug bounty; 99.9% uptime SLA with public status page; links to DPA, privacy policy and subprocessor list.	1	Summary only; detail sits in the Controls section.
NOT-02	NOT-01	Documentatio section	Request-gated documents: SOC 2 Type II and SOC 3 reports, ISO 27001 certificate and Statement of Applicability, HIPAA attestation, C5 attestation, 2026 security audit summary (web, mobile, desktop), 2026 Calendar and Mail penetration tests with retests, CAIQ/VSA/HECVAT dated July 2026, about 20 policy documents including IR plan, DR plan and SDLC policy, and a 2025 evidence of insurance valid until November 2026.	3	Access is by request; SOC 2 period not visible; no ISO 27701/27017/27018 certificates are listed as documents.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
NOT-03	NOT-01	Controls: Access control and authentication	SAML 2.0 SSO (Okta, Entra ID, Google Workspace, OneLogin) with SSO-only enforcement; two-step verification on all plans (SMS, TOTP, passkeys, backup codes); RBAC at page and teamspace level; least privilege with documented justification and owner approval; SCIM provisioning; session management; IP allowlisting; access reviews at least quarterly; access terminated within 24 hours of last working day; zero-trust access decisions.	2	Mix of customer-facing features and vendor-internal controls; vendor-authored and not independently verified.
NOT-04	NOT-01	Controls: Encryption and key management	TLS 1.2 or higher in transit; AES-256 at rest including backups across all products and regions; customer-managed keys via AWS KMS for Enterprise; three-layer envelope encryption; bcrypt password hashing; encryption audit trails.	2	Vendor-authored.
NOT-05	NOT-01	Controls: Data protection and privacy; AI data retention	DPA available; four-level data classification; formal deletion procedures on request or account termination with retention schedules by classification (no periods given); for AI features, zero data retention at LLM providers for Enterprise, up to 30 days otherwise, embeddings deleted within 60 days of content deletion.	2	General customer-content retention periods are not stated.
NOT-06	NOT-01	Controls: Incident response	24/7/365 on-call incident team; documented, management-approved IR plan; written notice without undue delay with standard breach notification within 72 hours; post-incident reviews with root-cause analysis; IR plan tested at least annually.	2	Contractual terms in the DPA were not reviewed.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
NOT-07	NOT-01	Controls: Business continuity and disaster recovery	BC plan reviewed annually; DR plan with cross-region backups; automated encrypted backups in geographically separate regions within the same compliance zone; BC/DR tested annually with documented results; 99.9% availability commitment with public uptime history.	2	RTO/RPO not stated. Two different status URLs are referenced.
NOT-08	NOT-01	Controls: Application security; Vulnerability management	SDLC with threat modelling and design review; SAST on every pull request; software composition analysis; mandatory peer review based on OWASP; annual third-party grey-box penetration testing of desktop, mobile and browser apps with critical/high findings remediated and validated; HackerOne bug bounty; responsible disclosure policy; annual secure-coding training.	2	Vendor-authored.
NOT-09	NOT-01	Controls: Change management	Development is separated from production and test; production environments are never reused for testing; production data is not used in development or test without customer coordination; pre-production testing and rollback strategy.	2	Vendor-authored.
NOT-10	NOT-01	Controls: Third-party risk management	Vendor risk assessments by criticality (questionnaires, attestation review, pentest evaluation); public subprocessor list; subprocessors reviewed at least annually; supplier code of conduct.	2	Vendor-authored.
NOT-11	NOT-01	Subprocessors (26)	26 subprocessors with purpose and location, including AWS (USA, EU, Korea, Japan), Cloudflare, Confluent, Splunk, Twilio (MFA), Vercel, and roughly a dozen AI/LLM and search providers (for example Anthropic, OpenAI, Google, Baseten, Cerebras, Fireworks, X.AI, Exa, Parallel) plus affiliated Notion entities.	2	Heavy AI-provider concentration increases fourth-party exposure.

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
NOT-12	NOT-01	Controls: Monitoring and logging	Audit logging of key events; 24/7/365 security monitoring; SIEM with detection rules maintained as code; tracking of privileged access changes; log archival and retention.	2	Vendor-authored.
NOT-13	NOT-01	Controls: AI governance and security	AI usage and governance policy reviewed annually; dedicated Securing AI programme; prompt-injection defences; no customer data used for AI training (contractual with AI subprocessors); permissions-aware AI; Enterprise AI kill switch; MCP server controls; AI activity logging; annual AI risk assessment; EU AI Act classification as deployer of limited-risk AI.	2	No independent AI management-system certification listed.
NOT-14	NOT-02	Security page (excerpt)	States achievement of ISO 27001, 27701, 27017 and 27018 covering an ISMS and a privacy information management system.	1	Excerpt only; no ISO 27701 certificate appears in the Trust Center document list.
GH-16	GH-05	Data Access / Privacy and Data Protection	Greenhouse states customer data access is restricted to employees who require it for their roles and follows least privilege.	2	Vendor-authored; no independent test evidence
GH-17	GH-05	Data Encryption	Customer data is stated to use TLS 1.2 or higher in transit and AES-256 at rest.	2	Vendor-authored; implementation is not independently verified
GH-18	GH-04	Can I securely delete my company's data from Greenhouse?	Candidate deletion is a hard delete from production; backups and versioned S3 files remain for 30 days, with complete purge on day 31; organization-level deletion follows the same backup caveat.	2	Vendor-authored; retention may vary by product/data category
GH-19	GH-04	What is Greenhouse's change management process?	All code changes require peer review and approval, code-quality/security scanning, testing, and higher-risk test plans before release.	2	Vendor-authored
GH-20	GH-04	How does Greenhouse test their changes?	Changes are tested in non-production before production release; major changes undergo additional testing and bake-in periods.	2	Vendor-authored

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
GH-21	GH-04	Which third-party services does Greenhouse use to support the application?	Greenhouse states it performs annual security reviews of all data subprocessors and requires subprocessors to sign DPAs.	2	Vendor-authored
GH-22	GH-04	What is Greenhouse's policy for notifying customers about security incidents?	For a significant security incident, customer notification is made within the timeframe specified in the customer license agreement and depends on incident nature.	2	Contract-specific timeframe is not public in this source
ATL-24	ATL-04	Section 3.2 Security Incidents	Atlassian must notify customers without undue delay and, where feasible, no later than 72 hours after becoming aware of a Security Incident.	2	Applies to the current public DPA
ATL-25	ATL-04	Sections 4.2-4.3 Sub-processing	Atlassian maintains an up-to-date subprocessor list and provides subscribed customers at least 30 days' notice before a new subprocessor may process Customer Personal Data; customers may object.	2	Contractual mechanism and objection remedy are described in the DPA
ATL-26	ATL-04	Section 6 Deletion and Return of Customer Personal Data	After agreement termination Atlassian must delete Customer Personal Data in accordance with documentation, subject to legal and standard backup/record-retention exceptions.	2	No fixed deletion day is specified in the DPA itself
ATL-27	ATL-05	Current subprocessor list	The current list identifies subprocessors and states Atlassian performs annual compliance reviews and transfer-impact assessments where required.	2	Customer-specific product/ subprocessor scope can vary
ATL-28	ATL-07	Locations and AWS regions	Atlassian offers selectable data-residency locations mapped to AWS regions, with Global/default hosting and pinned residency options where supported.	2	Availability depends on product and plan
ATL-29	ATL-04	Section 8 and transfer provisions	The DPA incorporates EU Standard Contractual Clauses and the EU-U.S. Data Privacy Framework (plus regional mechanisms) for international transfers.	2	Applicability depends on the relevant region and transfer

ID	Src	Locator	Finding (paraphrased)	Lvl	Limitation
ATL-30	ATL-08	AI Trust / Keep your data secure	Atlassian states third-party-hosted LLM providers do not use customer metadata or in-app data to train/improve their services and operate under zero-data-retention agreements; Atlassian may use governed metadata internally.	2	Feature-specific processing details can differ
ATL-31	ATL-08	AI Transparency Notes	Atlassian documents feature-level safeguards including provider restrictions, permission inheritance and defined retention for certain AI interactions.	2	Retention varies by feature
NOT-15	NOT-01	Controls / Incident response	The current Notion Trust Center states a standard breach notification within 72 hours and lists formal incident-response controls.	2	Vendor-authored; contractual DPA terms remain a separate artifact

D. Source register

ID	Publisher / title	URL	Type	Gr	Date shown	Retrieved / depth	Limitations
S-GH-01	Greenhouse Software – Greenhouse Software Trust Center (Conveyor platform)	https://trust.greenhouse.com/	Vendor trust portal	A	Page footer: subprocessor list "Last updated September 1, 2026"; announcements dated 2025-12-17, 2026-02-26, 2026-06-24	2026-09-24; Full page fetched	Report contents are gated; SOC 2 audit period and ISO certificate scope not visible; 251 knowledge-base answers are indexed by category only and were not retrieved
S-GH-02	Greenhouse Software – Greenhouse - Trust and security (marketing page)	https://www.greenhouse.com/security	Vendor public web page	B	Undated (footer copyright years are inconsistent)	2026-09-24; Full page fetched	Marketing-level statements without parameters such as protocol versions, RTO/RPO or test dates
S-GH-03	Greenhouse Software – Greenhouse security overview (support knowledge base)	https://support.greenhouse.io/hc/en-us/articles/4416552708507-Greenhouse-security-overview	Vendor knowledge-base article	C	Search index date 2026-03-02	2026-09-24; Search-result excerpt only (page not fetched in full)	Excerpt only; cites older ISO editions (27001:2013, 27701:2019) that conflict with S-GH-02 (27001:2022), so treated as partly stale

ID	Publisher / title	URL	Type	Gr	Date shown	Retrieved / depth	Limitations
S-ATL-01	Atlassian – Atlassian Trust Center (Conveyor platform)	https://customertrust.atlassian.com/	Vendor trust portal	A	Announcen dated 2025-03-14 to 2026-09-01	2026-09-24; Full page fetched	Only 6 documents and 169 FAQ answers indexed; white-paper and FAQ bodies were not retrieved; SOC 2 reports are product-specific (Jira, Confluence)
S-ATL-02	Atlassian – Atlassian Security Practices	https://www.atlassian.com/trust/security/security-practices	Vendor public web page	B	Undated	2026-09-24; Search-result excerpt only (page not fetched in full)	Excerpt only
S-ATL-03	Atlassian – Atlassian's Technical and Organisational Security Measures	https://www.atlassian.com/legal/security-measures	Vendor contractual exhibit (public)	A+	Effective 2025-10-07	2026-09-24; Full page fetched	States controls at policy level; no test results, RTO/RPO values or incident metrics; applicability by product not itemised
S-NOT-01	Notion – Notion Trust Center (Wolfia platform)	https://trust.notion.com/	Vendor trust portal	A	Undated page; documents dated 2025-2026 (e.g. CAIQ/ VSA/ HECVAT July 2026)	2026-10-04; Full page fetched; current control and incident-response sections reviewed in full	All reports remain request-gated; current Trust Center control statements are vendor-authored and not independently verified. DPA is linked but not used as the primary evidence for IR-02.
S-NOT-02	Notion – Notion Security & Compliance	https://www.notion.com/security	Vendor public web page	B	Undated	2026-09-24; Search-result excerpt only (page not fetched in full)	Excerpt only; no certificate artifacts listed for 27701/ 27017/27018

ID	Publisher / title	URL	Type	Gr	Date shown	Retrieved / depth	Limitations
S-GH-04	Greenhouse Software – Greenhouse security overview (support knowledge base)	https://support.greenhouse.io/hc/en-us/articles/4416552708507-Greenhouse-security-overview	Vendor knowledge-base article	B	Updated March 2, 2026	2026-10-04; Full page fetched and read in full	Vendor-authored support article; some legacy certification references are superseded by the current Trust Center
S-GH-05	Greenhouse Software – AI/ML Security & Privacy	https://support.greenhouse.io/hc/en-us/articles/24315491395227-AI-ML-Security-Privacy	Vendor security/privacy article	B	Updated January 30, 2026	2026-10-04; Full page fetched and read in full	Vendor-authored; AI-specific statements are not independently verified
S-ATL-04	Atlassian – Atlassian Data Processing Addendum	https://www.atlassian.com/legal/data-processing-addendum	Vendor contractual document (public)	A+	Effective August 17, 2026	2026-10-04; Full page fetched and relevant sections read in full	Public DPA; product-specific documentation and backup/record retention exceptions still require context
S-ATL-05	Atlassian – List of Data Subprocessors	https://www.atlassian.com/legal/sub-processors	Vendor legal disclosure	A	Effective May 15, 2026	2026-10-04; Full page fetched and relevant sections read in full	List is current as published; customer-specific contractual terms may vary
S-ATL-06	Atlassian – Security in Software Development at Atlassian	https://www.atlassian.com/trust/security/security-in-development	Vendor security documentation	B	Current page retrieved October 4, 2026	2026-10-04; Full page fetched and read in full	Vendor-authored control description
S-ATL-07	Atlassian – Understand data residency	https://support.atlassian.com/security-and-access-policies/docs/understand-data-residency/	Vendor support documentation	B	Current page retrieved October 4, 2026	2026-10-04; Full page fetched and read in full	Availability depends on product and subscription
S-ATL-08	Atlassian – AI Trust	https://www.atlassian.com/trust/ai	Vendor AI security documentation	B	Current page retrieved October 4, 2026	2026-10-04; Full page fetched and relevant FAQ sections read in full	Vendor-authored; applies to described Atlassian AI services and may vary by feature

E. Framework and standards references

ID	Publishe	Title	Version / date	URL	Role
F-NIST-161	NIST	SP 800-161 Rev. 1 - Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations	May 2022; errata update Nov 2024	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Primary C-SCRM reference; supplier criticality tiering; control mapping
F-NIST-1326	NIST	SP 1326 - C-SCRM Due Diligence Assessment Quick-Start Guide	Final, 2026-07-08	https://csrc.nist.gov/pubs/sp/1326/final	Defines basic (public-information) vs enhanced due diligence and five assessment components; used to scope this project
F-NIST-30	NIST	SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments	Sep 2012	https://csrc.nist.gov/pubs/sp/800/30/r1/final	Likelihood x impact reasoning; semi-quantitative 5-level scales; uncertainty and assumptions documentation
F-NIST-CSF2	NIST	Cybersecurity Framework 2.0 (Govern function, GV.SC supply-chain category)	Feb 2024	https://www.nist.gov/cyberframework	Control mapping (function.category identifiers)
F-NIST-53	NIST	SP 800-53 Rev. 5 - Security and Privacy Controls (incl. SR supply-chain family)	Rev. 5 (update 1)	https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final	Control mapping (control identifiers)
F-ISO-27001	ISO/IEC	ISO/IEC 27001:2022 - Information security management systems (Annex A 5.19-5.23 supplier and cloud controls)	2022	https://www.iso.org/standard/27001	Control mapping (Annex A references); certificate interpretation. Standard text is paywalled and is not reproduced
F-ISO-27036	ISO/IEC	ISO/IEC 27036 series - Information security for supplier relationships	Parts 1-4	https://www.iso.org(catalogue)	Structure of supplier due diligence, agreements and monitoring. Standard text is paywalled and is not reproduced

ID	Publishe	Title	Version / date	URL	Role
F-ISO-31000	ISO	ISO 31000:2018 - Risk management guidelines	2018	https://www.iso.org/iso-31000-risk-management.html	Risk process: context, identification, analysis, evaluation, treatment, monitoring, communication
F-ISO-27005	ISO/ IEC	ISO/IEC 27005:2022 - Information security risk management	2022	https://www.iso.org(catalogue)	Information-security-specific risk assessment method
F-ISO-42001	ISO/ IEC	ISO/IEC 42001:2023 - AI management systems	2023	https://www.iso.org/standard/42001	Interpretation of the AI governance control (AI-01)
F-AICPA-TSC	AICPA	SOC 2 Trust Services Criteria (Common Criteria CC1-CC9, A1, C1, P-series)	2017 criteria, revised points of focus 2022	https://www.aicpa-cima.com(SOCsuite)	Cross-reference from controls to SOC 2 criteria
F-GDPR	European Union	Regulation (EU) 2016/679 - Articles 28, 33, 44-46	2016	https://eur-lex.europa.eu/eli/reg/2016/679/oj	Processor obligations, breach notification 'without undue delay', international transfers

F. Vendor follow-up request list

Ordered by residual score within each vendor. Each request targets a Partial or Not-evidenced control.

F.1 Atlassian

Control	Rating	Request
IAM-04 Access review and timely termination	High	Ask for review frequency and de-provisioning SLA.
DAT-02 Data retention and deletion	High	Confirm product-specific deletion timing and backup/record-retention periods.
ASSUR-01 SOC 2 Type II	Medium	Confirm report scope covers JSM and other in-scope products; obtain FY26 report and bridge letter.
ASSUR-03 Privacy assurance (ISO/IEC 27701, 27018 or equivalent)	Medium	Ask whether ISO 27701 is held or planned.
SUP-03 Cyber insurance / financial backstop	Medium	Request insurance certificate.
ASSUR-04 Evidence currency	Medium	Obtain the FY26 SOC 2 report and bridge letter; request FY27 timeline.

F.2 Greenhouse Software

Control	Rating	Request
IAM-04 Access review and timely termination	Critical	Request evidence of periodic access reviews and timely termination/deprovisioning.
IAM-02 Multi-factor authentication	High	Ask whether MFA can be enforced for all users and admins, and which factors are supported.
IR-02 Customer incident notification with a defined timeframe	High	Confirm the contractual customer-notification timeframe in the license agreement/MSA.
BC-01 Disaster recovery	Medium	Request BC/DR summary with RTO/RPO and dated test results or testing cadence.
DAT-05 Data residency and international transfer mechanism	Medium	Ask whether EU-only hosting is available; verify DPF registry entry.
ASSUR-04 Evidence currency	Medium	Obtain SOC 2 period end date and bridge letter.

F.3 Notion

Control	Rating	Request
DAT-02 Data retention and deletion	High	Ask for deletion timeframe after termination.

Control	Rating	Request
ASSUR-03 Privacy assurance (ISO/IEC 27701, 27018 or equivalent)	Medium	Request ISO 27701 and 27018 certificates.
DAT-05 Data residency and international transfer mechanism	Medium	Ask which transfer mechanism applies and whether region pinning is available.
SUP-03 Cyber insurance / financial backstop	Medium	Request certificate showing cyber liability limits and renewal.